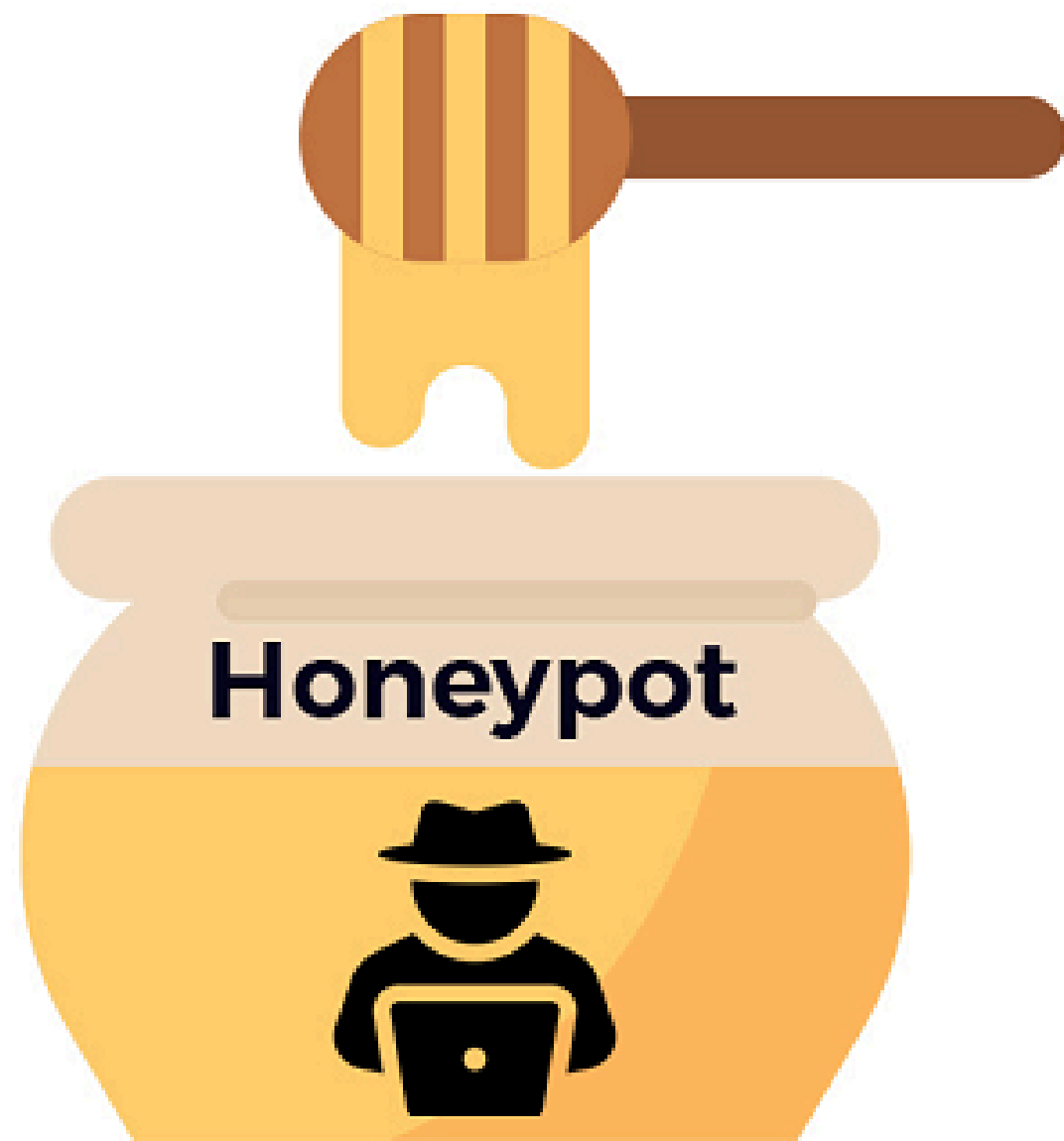




Honeypot

Lê Minh Tấn - 23521398

Nguyễn Quang Thắng - 23521425

Trần Việt Thắng - 23521433

Nhóm 8

Nội dung

1. Giới thiệu
2. Deployment architecture
3. Technology
4. Các kịch bản và demo

Nhóm 9



Context

Hiện nay, các tài sản số (digital assets) đang phải chịu nhiều cuộc tấn công liên tục. Số lượng các mối đe dọa mạng (cyber threats) ngày càng tăng lên với mức độ ngày càng tinh vi và phức tạp.

- **Tấn công diễn ra liên tục và tự động.**
- **Mục tiêu đa dạng.**
- **Kỹ thuật tấn công luôn thay đổi.**
- **Phòng thủ truyền thống có giới hạn.**





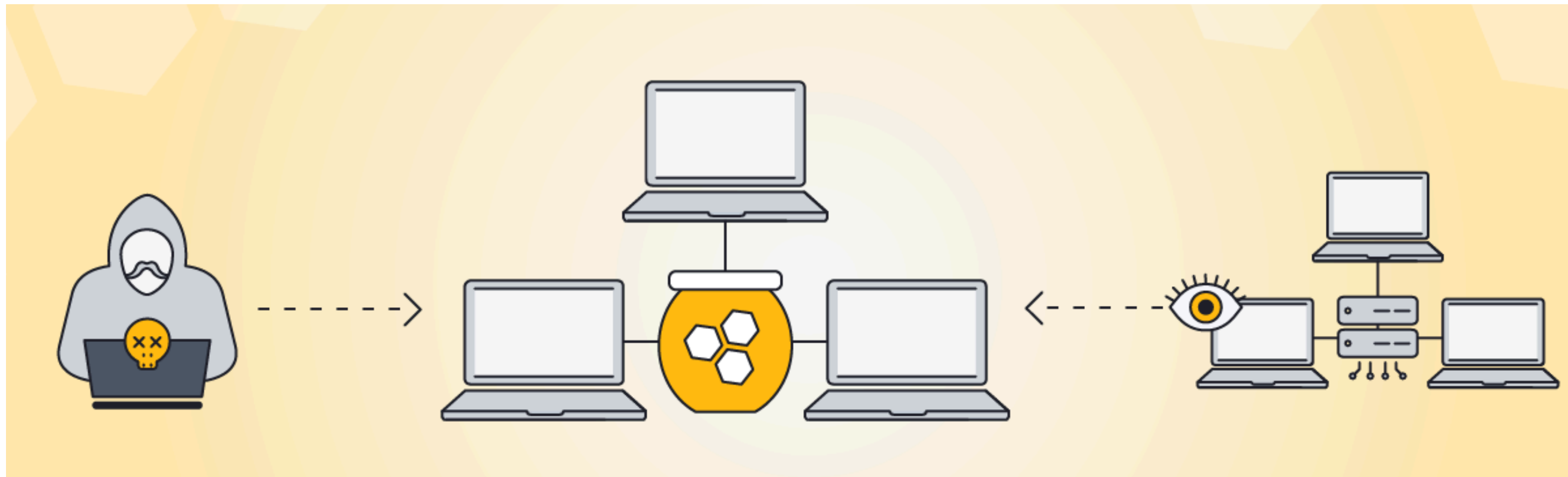
Honeypot là gì?

Honeypot là một hệ thống hoặc máy tính được tạo ra để cố tình làm mồi nhử, thu hút hacker tấn công vào

- ✓ Honeypot giúp chúng ta có thể quan sát tường tận cách thức kẻ tấn công hành động: chúng dùng công cụ gì, khai thác lỗ hổng nào, di chuyển trong hệ thống ra sao
- ✓ Honeypot còn là một hệ thống cảnh báo sớm cực kỳ hiệu quả, giúp phát hiện ra các kỹ thuật tấn công mới ngay từ khi chúng xuất hiện, trước cả khi các hãng bảo mật kịp cập nhật chữ ký nhận dạng.
- ✓ Honeypot cho phép chúng ta chủ động giăng bẫy. Nó không chỉ là một hàng rào phòng thủ mà còn là một công cụ "câu nhử" và làm lãng phí thời gian của kẻ tấn công.

Deployment architecture

- * **VM-A: T-Pot Server:** Trung tâm honeypot, chứa nhiều dịch vụ giả lập (SSH, SMB, HTTP...), ghi nhận hành vi tấn công và hiển thị log qua Kibana.
- * **VM-B: Worm Simulator:** Mô phỏng hành vi tấn công hoặc lây lan của worm trong mạng nội bộ
- * Dùng **Internal Network / Host-Only** → 2 máy chỉ nói chuyện với nhau, không ra Internet.



Technology Stack

- Hệ điều hành: Ubuntu Server (T-Pot CE)
- Honeypot services: Cowrie, Dionaea, ElasticPot, Conpot, Mailoney
- Log pipeline: Filebeat → Logstash → Elasticsearch
- Dashboard: Kibana
- Worm mô phỏng: VM (Windown, Linux)
- Network monitoring: Suricata / Wireshark



Feature of core Technology

T-Pot Honeypot Platform:

- Kết hợp nhiều honeypot trong cùng một môi trường Docker.
- Ghi log tự động và chuyển sang ELK stack để phân tích.

Cowrie Honeypot:

- Mô phỏng SSH/Telnet để ghi lại lệnh attacker gõ.
- Lưu trữ transcript chi tiết của phiên tấn công.

Dionaea Honeypot:

- Mô phỏng các dịch vụ SMB/RCP/FTP để thu thập mẫu mã độc.
- Tự động tải xuống và lưu trữ binary để phân tích sau.

Conpot Honeypot:

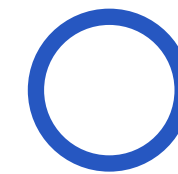
- Mô phỏng các hệ thống điều khiển công nghiệp (ICS/SCADA)
- Ghi nhận hành vi dò quét, kết nối, và tương tác tự động nhắm vào ICS

ELK Stack (Elasticsearch, Logstash, Kibana).

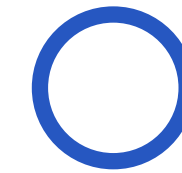
- Thu thập và xử lý log tập trung.
- Cho phép tìm kiếm IOC, lọc dữ liệu, và hiển thị trực quan qua Kibana Dashboard.

Docker:

- Giúp triển khai các honeypot cô lập, tránh ảnh hưởng hệ thống chính.
- Dễ dàng mở rộng hoặc reset từng thành phần



Kịch bản triển khai

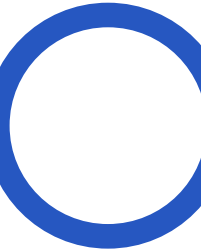


Cowrie

Mirai là một IoT botnet/worm nổi tiếng (phổ biến từ 2016) — nó quét Internet, thử các username/password mặc định trên dịch vụ Telnet/SSH của thiết bị IoT. Cowrie giả lập một máy chủ sử dụng dịch vụ SSH hoặc Telnet.

Dionaea

Nổi bật ở khả năng lây lan trong mạng nội bộ thông qua lỗi dịch vụ, shares và weak autorun; nó còn mở backdoor và tải module bổ sung



Conpot

Triển khai honeypot Conpot trong T-Pot để mô phỏng dịch vụ ICS, ghi nhận hành vi dò quét và tương tác tự động (worm-like) từ attacker phục vụ phân tích an ninh OT.

KB Triển khai: Mirai (IoT botnet)

Mirai là một IoT botnet/worm nổi tiếng (phổ biến từ 2016) — là phần mềm độc hại lây nhiễm vào các thiết bị thông minh, chúng biến thành một mạng lưới các bot hoặc “zombie” được điều khiển từ xa. Mạng lưới bot này được gọi là botnet thường được sử dụng để phát động các cuộc tấn công DDoS.

Giai đoạn 1: Quét cổng (Scanning)

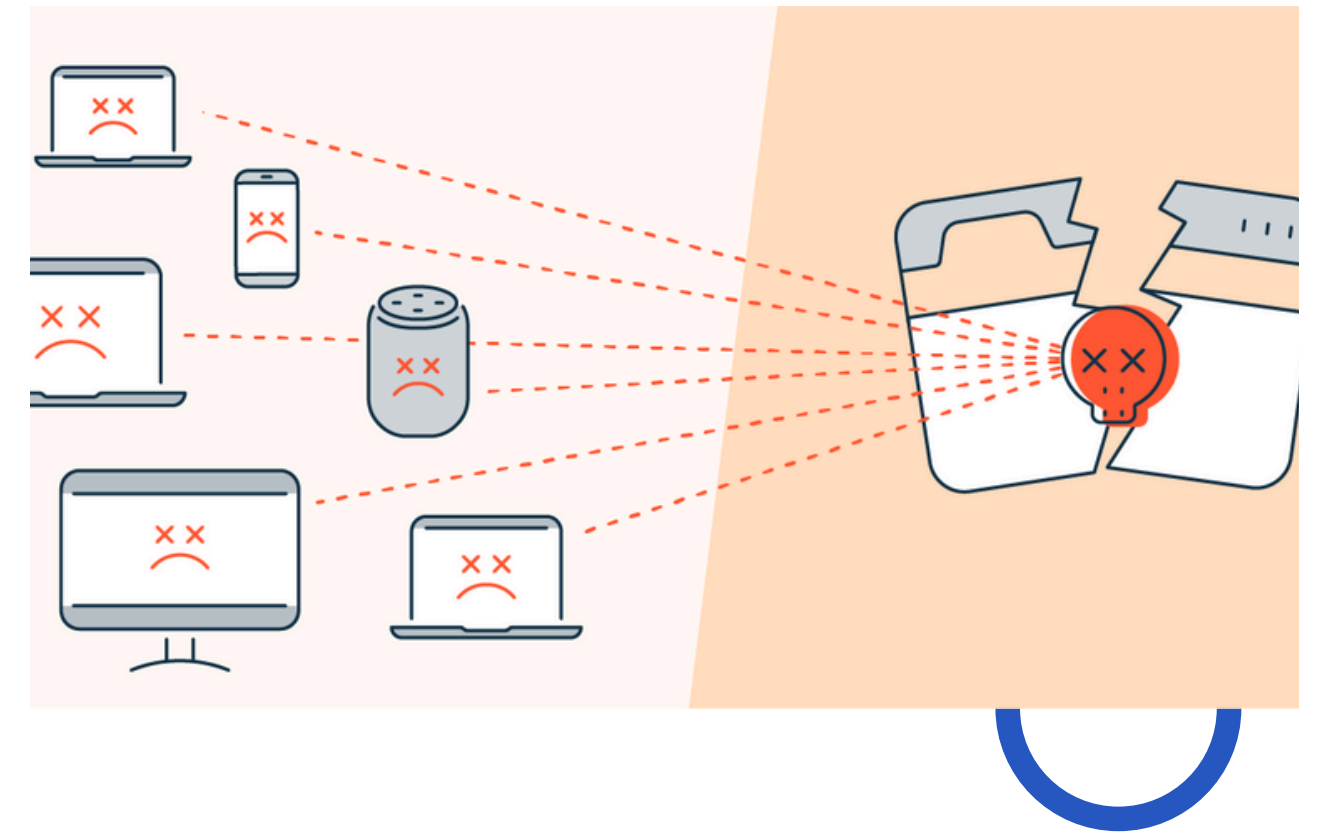
- Hành động: Botnet quét hàng loạt dải IP trên Internet để tìm các cổng Telnet đang mở (22,23,2323).
- Dịch vụ hoạt động: Honeytrap, Cowrie

Giai đoạn 2: Dò mật khẩu (Brute-force)

- Hành động: Khi thấy cổng mở, Bot tự động thử các cặp tài khoản/mật khẩu mặc định (ví dụ: admin/admin, root/1234).
- Dịch vụ hoạt động: Honeytrap, Cowrie

Giai đoạn 3: Chạy mã độc

- Hành động: Nếu login thành công sẽ thực hiện các câu lệnh chạy mã độc.
- Dịch vụ hoạt động: Honeytrap



Phương pháp giả lập Environment của Cowrie

1. Phương pháp giả lập: Low-to-Medium-Interaction (Tương tác trung bình)

- **Fake Shell:** Không chỉ giả lập giao thức, Cowrie cung cấp một môi trường dòng lệnh (Shell) giả lập, cho phép hacker đăng nhập và thực thi lệnh.
- **Hệ thống tệp ảo (Fake Filesystem):** Sử dụng tệp fs.pickle để mô phỏng cấu trúc cây thư mục Linux (Ubuntu). Mọi thao tác ls, cd, rm đều diễn ra trên tệp ảo này, không ảnh hưởng đến hệ thống thật.

2. Công nghệ thu thập dữ liệu chủ động

- **Command Emulation:** Sử dụng tệp JSON để trả về kết quả giả cho các lệnh hệ thống (như `uname -a`, `ipconfig`, `cat /etc/passwd`).
- **Session Playback (TTY Log):** Ghi lại toàn bộ phiên làm việc của hacker dưới dạng video. Cho phép "phát lại" để quan sát trực quan từng thao tác gõ phím.
- **SFTP/SCP Capture:** Tự động lưu giữ các tệp tin mà hacker tải lên server (như script đào tiền ảo, botnet) vào thư mục cách ly.

Các environment giả lập của Cowrie

Thành phần	Thông số giả lập (Env)	Ý nghĩa & Mục tiêu dự dõ
Dịch vụ	SSH (22), Telnet (23)	Bầy các cuộc tấn công chiếm quyền điều khiển và Brute-force mật khẩu.
Hệ điều hành	Ubuntu 22.04 LTS	Tạo vỏ bọc một máy chủ hiện đại, phổ biến để thu hút các dòng Malware Linux mới nhất.
Xác thực	AuthRandom (Ngẫu nhiên)	Đánh lừa hacker bằng cách cho phép "đăng nhập thành công" sau một số lần thử để thu thập hành vi hậu khai thác.
SFTP/SCP	Enabled	Thu thập các mẫu mã độc (Payload) mà hacker định cài đặt vào hệ thống sau khi chiếm quyền.

The image shows a Kibana dashboard for T-Pot, which is a honeypot framework. The dashboard is titled "elastic" and displays several panels, all of which show "No results found". The panels include:

- Honeypot Attacks: N/A
- Honeypot Attacks Bar
- Attacks by Destination Port Histogram
- Attacker Src IP Reputation
- Attacks by Honeypot
- Attacks by Country and Port

Overlaid on the dashboard is a VMware Workstation window titled "node2 - VMware Workstation". The window shows a Linux desktop environment with a terminal window open. The terminal prompt is "thang@node2: ~" and the command being executed is "thang@node2: \$./nrat_like_tpot.sh". The terminal output is currently empty. The VMware Workstation window also shows a file explorer on the left with a tree view containing "My Computer", "node3", "node2", and "node1".

KB Triển khai: Dionaea

1. Mô hình triển khai

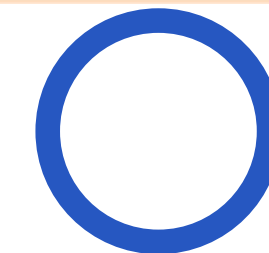
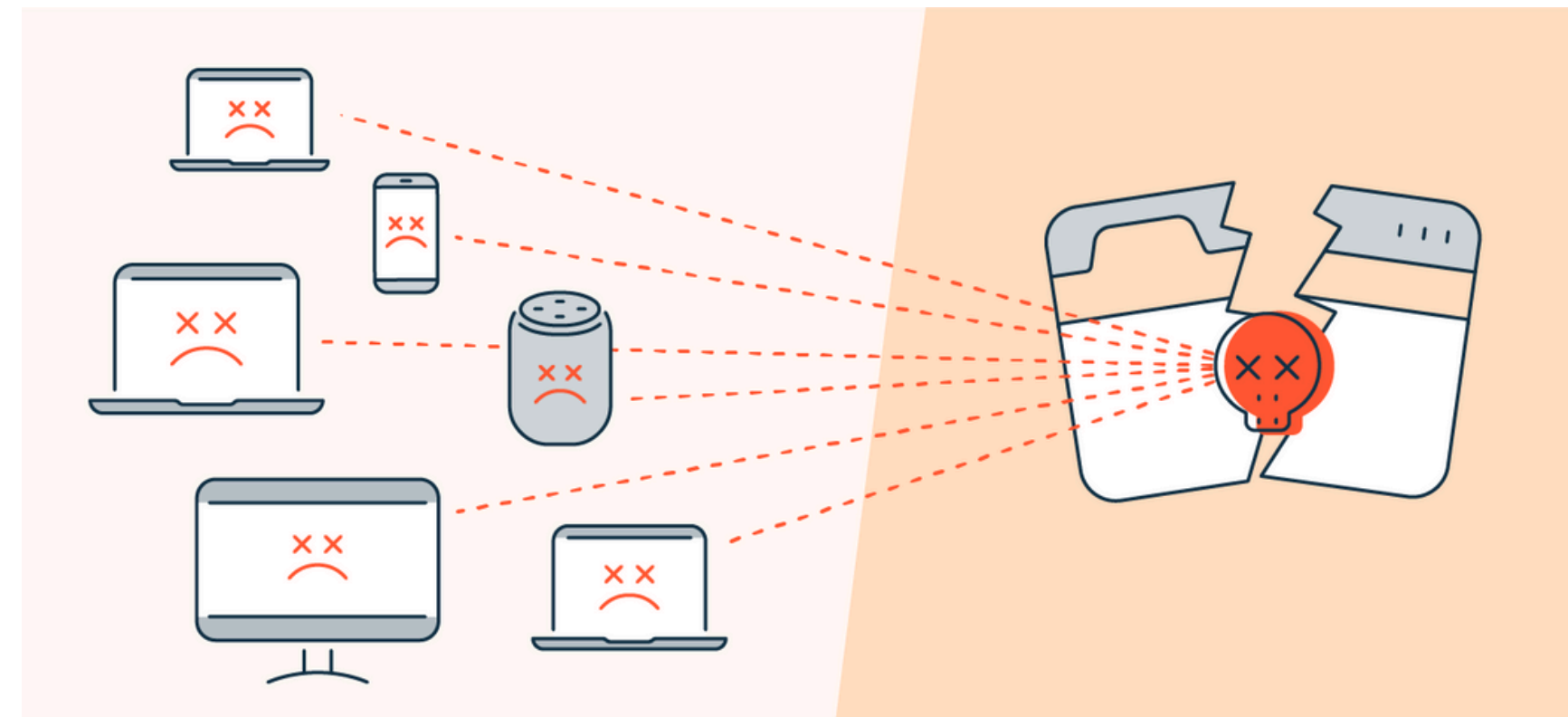
- Đối tượng: Kali Linux (Attacker) -> T-Pot/Dionaea (Target).
- Mục tiêu: Kiểm tra khả năng phát hiện, ghi nhận Malware, Brute-force và Scanning.

2. Các Vector tấn công chính

- SMB (Cổng 445): Mô phỏng hành vi malware/ransomware dropper, đẩy file thực thi nhằm kiểm tra khả năng thu thập mẫu của Dionaea
- RPC (Cổng 135): Mô phỏng hoạt động reconnaissance (pre-exploit).
- FTP (Cổng 21): Mô phỏng brute-force và anonymous login, hành vi phổ biến của botnet và malware tự động..

3. Kết quả thu thập được

- Dấu vết tấn công: Ghi nhận đầy đủ timeline kết nối, giao thức và lệnh tương tác với honeypot.
- Thông tin xác thực: Thu thập danh sách user/password được sử dụng trong các cuộc brute-force.
- Mẫu malware: Các file được tải lên được cô lập, lưu trữ và phân tích trong hệ thống honeypot.



Phương pháp giả lập Environment của Dionaea

1. Phương pháp Low-Interaction (Tương tác thấp)

- **Định nghĩa:** Sử dụng mã nguồn (Python/C) giả lập cú pháp giao thức thay vì chạy dịch vụ thật.
- **Mục tiêu:** Cách ly mã độc với hệ thống, triệt tiêu rủi ro bị chiếm quyền điều khiển (RCE).

2. Cơ chế State Machine (Máy trạng thái)

- **Mô phỏng Handshake:** Tái tạo trình tự logic của các bước bắt tay giao thức.
- **Duy trì kết nối:** Tự động phản hồi gói tin để đánh lừa các tiến trình dò quét (Botnet), kéo dài thời gian tương tác nhằm thu thập dữ liệu.

3. Công nghệ Libemu & Shellcode Detection

- **Emulation Sandbox:** Giả lập kiến trúc CPU x86 để thực thi shellcode trong môi trường cô lập.
- **Auto-Capture:** Tự động phát hiện và truy xuất (download) các tệp nhị phân mã độc (Malware Binaries) khi nhận diện được lệnh tải tệp từ payload của hacker.

Các environment giả lập của Diona

Thành phần	Thông số giả lập (Env)	Ý nghĩa & Mục tiêu dự dõ
Dịch vụ tệp tin	Windows SMB (Cổng 445)	Giả lập máy chủ chia sẻ tệp Windows. Bẫy Ransomware/Worm và thu giữ mã độc tự lây lan ngang (Lateral Movement).
Truyền tải dữ liệu	FTP/TFTP (Cổng 21, 20, 69)	Giả lập Server lưu trữ. Bẫy Malware Dropper, bắt giữ các tệp tin trung gian mà hacker tải lên để thực thi giai đoạn tiếp theo.
Điều khiển từ xa	Service Mapping/RPC (Cổng 135)	Giả lập danh bạ dịch vụ Windows. Phát hiện các hoạt động Dò thám (Reconnaissance) và Fingerprinting hệ thống.
Cơ sở dữ liệu	MSSQL / MySQL (Cổng 1433, 3306)	Giả lập Database Server nhạy cảm. Bẫy các cuộc tấn công Brute-force để thu thập bộ từ điển tài khoản/mật khẩu thực tế.
Hạ tầng kết nối	IoT/MQTT (Cổng 1883, 1900)	Giả lập các thiết bị thông minh, cảm biến. Phát hiện các biến thể mã độc IoT Botnet (như Mirai) tấn công vào hạ tầng Smart Home.

KB Triển khai: Dionaea

Giai đoạn 1: Dò thám Hệ thống (Reconnaissance) - Port 135

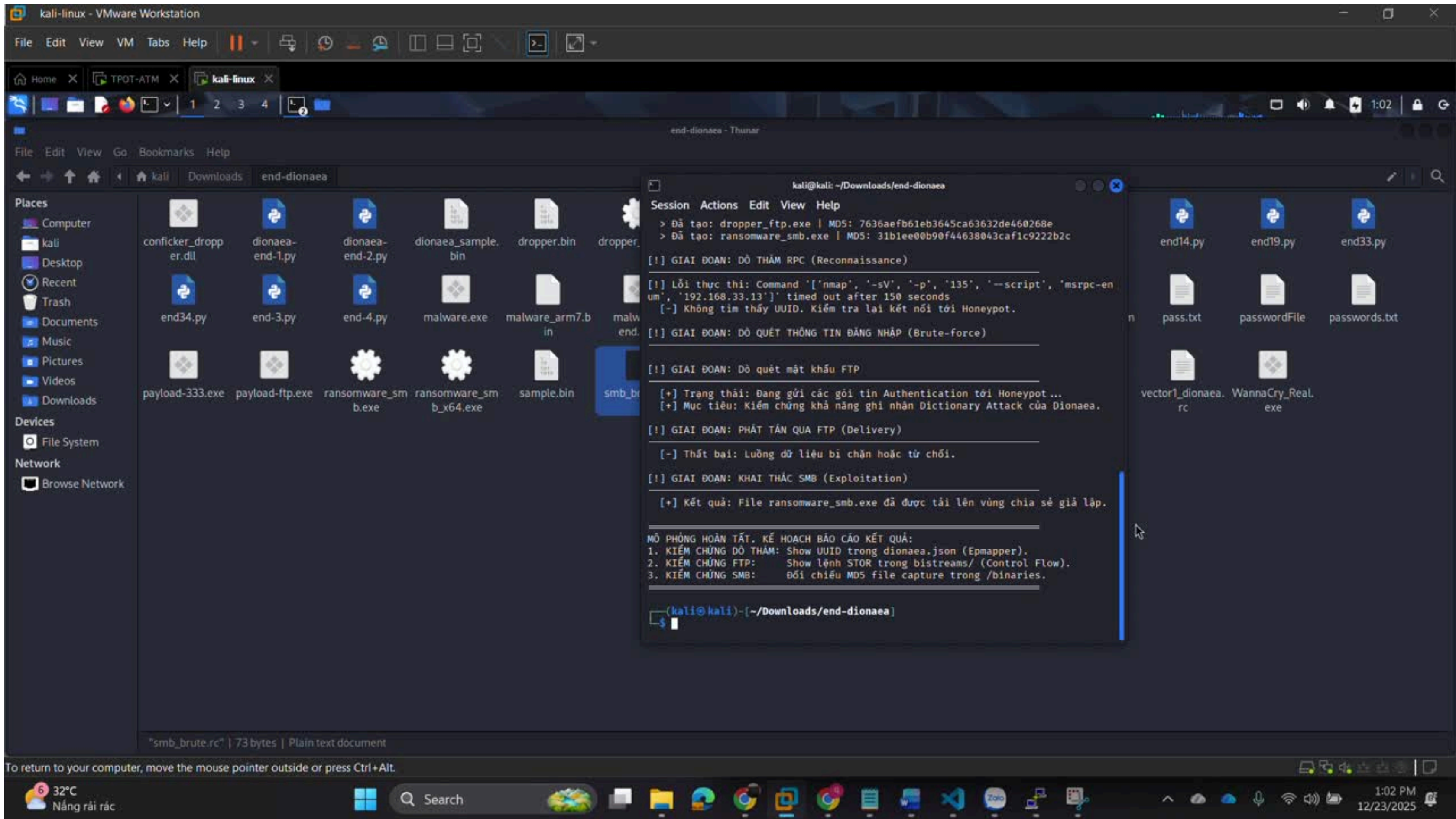
- Hành động: Code thực hiện quét cổng 135 (MSRPC).
- Mục tiêu: Xác định mục tiêu là hệ điều hành Windows thông qua dịch vụ Endpoint Mapper.
- Kết quả: Dionaea phản hồi dịch vụ ảo, lừa máy Kali rằng đây là Windows thật. Hệ thống ghi nhận log giao thức epmapper.

Giai đoạn 2: Tấn công Truy cập FTP (Credential Access & Delivery) - Port 21

- Hành động: 1. Brute-force: Thử nghiệm đăng nhập với danh sách tài khoản (admin, root, anonymous). 2. Delivery: Sử dụng lệnh STOR để đẩy file dropper_ftp.exe lên server.
- Kết quả: Ghi nhận toàn bộ thông tin tài khoản brute-force. Đối với lệnh STOR, hệ thống ghi lại hành vi điều khiển trong Log JSON và luồng dữ liệu thô (Bistreams).

Giai đoạn 3: Khai thác & Chiếm quyền (Exploitation) - Port 445

- Hành động: Sử dụng Metasploit (upload_file) đẩy file ransomware_smb.exe qua giao thức SMB.
- Kết quả: Honeypot cho phép tải lên hoàn toàn file vật lý để phục vụ công tác giám định.



KB Triển khai: CONPOT

- **Honeypot loại OT:** hướng đến hệ thống điều khiển công nghiệp (ICS/SCADA), mô phỏng các thiết bị như PLC hoặc RTU và các giao thức công nghiệp nhằm thu hút và ghi nhận hành vi tấn công
- **Đại diện:** Conpot
- **Mục tiêu:** mô phỏng hành vi của malware ICS dạng worm, trong đó attacker tự động dò quét mạng để phát hiện các dịch vụ ICS, sau đó thực hiện kết nối và tương tác lặp lại nhằm tạo dữ liệu cho honeypot phân tích
- **Môi trường:**
 - T-Pot VM : triển khai honeypot Conpot, thu thập vào hiển thị log
 - Attacker VM: chạy script mô phỏng worm-like behavior
- **Mô phỏng hành vi tấn công (worm-like):**
 - Reconnaissance: dò quét dải IP để phát hiện dịch vụ ICS
 - Worm-like behavior: kết nối vào dịch vụ giả lập và lặp lại hành vi theo chu kỳ cố định.

Các environment giả lập của Conpot

Thành phần	Thông số giả lập (Env)	Ý nghĩa & Mục tiêu dự dõ
Giao thức lưới điện	IEC104 (Cổng 2404)	Giả lập trạm biến áp, hệ thống truyền tải. Bẫy các cuộc tấn công nhắm vào hạ tầng lưới điện thông minh.
Hệ thống Xăng dầu	Guardian AST (Cổng 10001)	Giả lập hệ thống quản lý bồn chứa. Theo dõi hành vi can thiệp trái phép vào cảm biến lưu lượng và mức nhiên liệu.
Quản trị phần cứng	IPMI (Cổng 623/UDP)	Giả lập giao diện quản lý phần cứng máy chủ. Phát hiện hành vi chiếm quyền điều khiển ở mức thấp nhất (Out-of-band).
Đo lường dân dụng	Kamstrup 382 (Cổng 1025, 50100)	Giả lập công tơ điện thông minh (Smart Meter). Phát hiện các kỹ thuật tấn công/can thiệp vào hệ thống đo lường dân dụng.
Quản lý mạng OT	SNMP (Cổng 161/UDP)	Giả lập giao thức quản lý thiết bị. Thu thập thông tin từ giai đoạn dò quét (Reconnaissance) của kẻ tấn công.

Phương pháp giả lập Environment của Conpot

1. Mức độ tương tác: Low-to-Medium Interaction

- Conpot không chạy PLC thật, mà mô phỏng giao thức công nghiệp bằng script, đủ để attacker tương tác đồng thời đảm bảo không gây rủi ro vận hành
- Phù hợp cho honeypot vì ưu tiên quan sát hành vi thay vì chức năng đầy đủ

2. Kiến trúc dựa trên template

- Sử dụng các template cấu hình sẵn để định danh thiết bị ICS giả lập
- Template mô tả thông tin thiết bị, banner và phản hồi đặc trưng nhằm tạo cảm giác hệ thống công nghiệp thật

3. Mô phỏng phản hồi và quản lý phiên:

- Conpot phản hồi nhất quán với các hành vi dò quét (nmap, công cụ chuyên dụng)
- Giúp attacker tin rằng đang tương tác với ICS thật, từ đó tạo ra log có giá trị cho Blue team phân tích

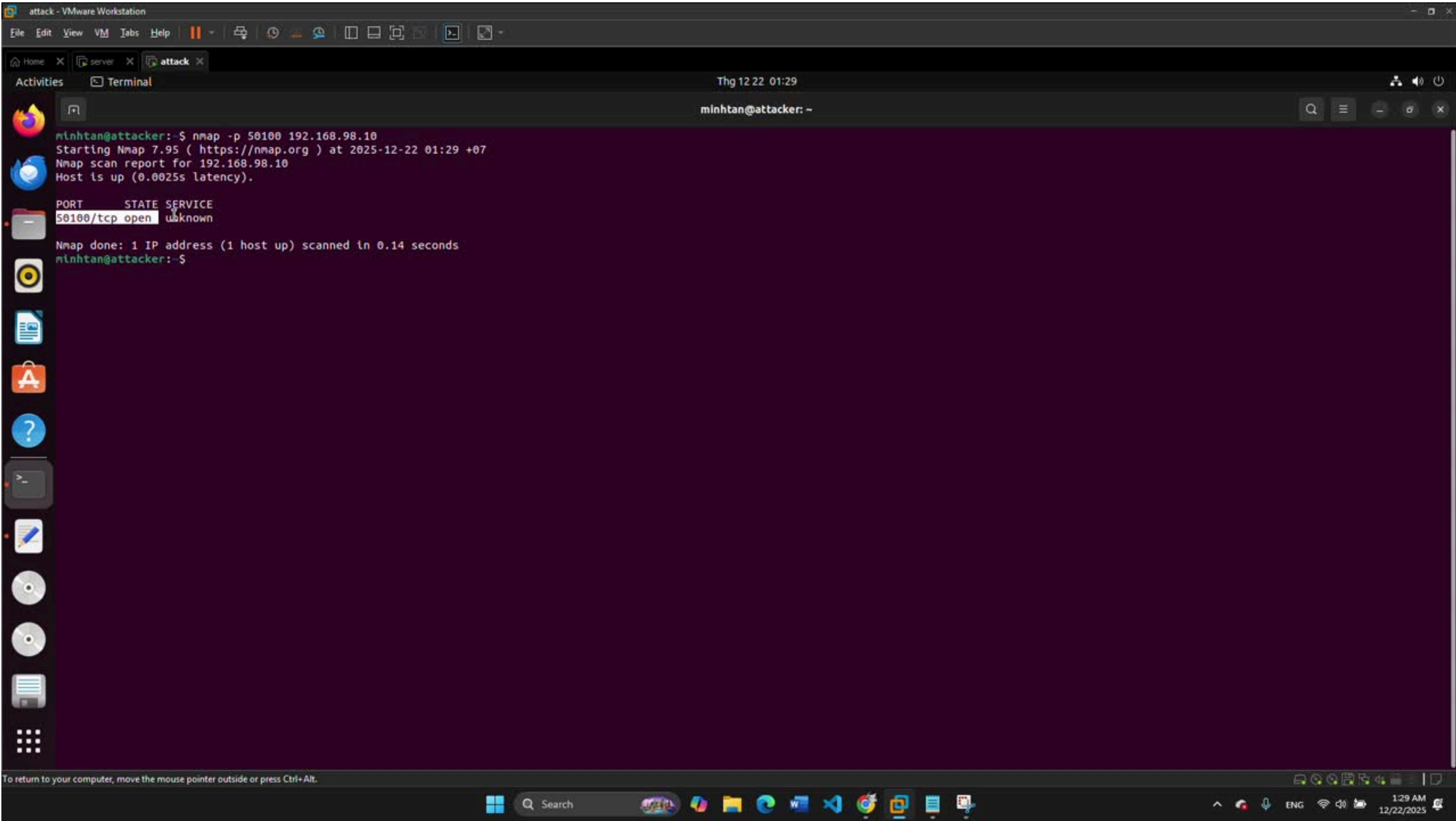
KB Triển khai: CONPOT

[Home](#)

[Discussion](#)

[Deployment](#)

[Challenge](#)



[Home](#)[Discussion](#)[Deployment](#)[Challenge](#)

Thank You